Vouch

AGENTIC AI + BLOCKCHAIN + OPEN SOURCE

Your app trusts code written by strangers and updated automatically. Vouch reads every package update before install, explains what it found, and anchors the verdict on Hyperledger Besu.

Trusted packages have already shipped malicious updates.

PROBLEM

- **event-stream, 2018:** malicious `flatmap-stream` entered `event-stream@3.3.6` through a maintainer handoff.
- **XZ Utils, 2024:** CVE-2024-3094 put a backdoor in upstream release artifacts.
- **npm, 2025:** GitHub reported the Shai-Hulud worm used compromised maintainer accounts and postinstall scripts.

<footer>Sources: npm blog, 2018. Openwall and NVD, 2024. GitHub Blog, 2025.

</footer>

Hashes and signatures do not say the bytes are safe.

GAP

- Lockfile hashes prove the registry bytes did not change.
- Provenance proves who published a build.
- Closed scanners create private verdicts.
- None gives a public, challengeable, evidence-cited verdict for the exact tarball.

Vouch turns every exact package version into a verifiable trust decision.

SOLUTION

1. **Audit agent:** diff-first static review with deterministic detectors and a tool-using investigator.
2. **Attestation registry:** verdicts keyed by npm integrity hash and anchored on Hyperledger Besu.
3. **CLI and GitHub Action:** `vouch check` blocks risky lockfile entries in CI.

The live demo proves the attack is stopped before install.

DEMO FLOW

1. Clean demo app passes `vouch check`.
2. Compromised `color-tones@2.3.1` is audited.
3. Agent flags postinstall, encoded payload text, and prompt injection.
4. Malicious verdict lands in the attestation ledger.
5. Compromised lockfile is blocked.
6. A wrong Safe verdict is challenged and reputation drops.

Architecture keeps heavy evidence off-chain and trust on-chain.

SYSTEM

Registry or fixtures -> fetch and verify -> diff -> detectors -> agent tools -> canonical report -> report hash -> Besu attestation -> CLI, API and dashboard.

Only hash, verdict, score, auditor and URI go on-chain. Reports stay off-chain and are independently hashable.

The agent is designed for hostile package contents.

AGENTIC AI

- Treat package text as untrusted data.
- Flag prompt injection aimed at AI or human reviewers.
- Validate every evidence item against real files and line ranges.
- Skip LLM calls when deterministic signals are clean.

The blockchain layer creates shared accountability.

BESU REGISTRY

- Verdicts bind to `sha512-...` integrity, not package names.
- Auditors stake before attesting.
- Challenges can uphold or overturn attestations.
- Wrong auditors lose reputation and demo stake.

Vouch is different because the verdict is public, exact and explainable.

NOVELTY

- Exact-byte attestations prevent silent verdict carryover.
- Evidence is machine-checkable.
- Diff-first review focuses on what changed.
- Prompt-injection-aware scanning treats malicious instructions as a signal.
- Auditor economics make trust earned, not assumed.

Judges asked for impact, feasibility, novelty, architecture and revenue.

PROOF

- **Impact:** every Node project carries transitive dependency risk.
- **Feasibility:** CLI, API, dashboard, fixtures, reports and contract source run locally.
- **Novelty:** exact-byte public verdicts with cited evidence.
- **Architecture:** agent, report store, registry, CLI and dashboard.
- **Revenue:** open core plus team cloud, compliance packs and auditor marketplace.

Vouch has a clear buyer and a path to a business.

REVENUE MODEL

- Free CLI, GitHub Action and public lookups.
- Team plan for private registry scans, dashboards and alerts.
- Compliance tier for SBOM and attestation evidence packs.
- Auditor marketplace where companies fund priority reviews.
- Data API for security vendors.

Roadmap turns the demo into production coverage.

NEXT

- Besu dev network and public testnet deployment.
- IPFS report storage.
- PyPI support.
- DAO arbitration.
- Publish `vouch-audit` package.

Team: Karan Raval.